whalebone



Agentic AI in Threat Intelligence: LLMs and Beyond

ROMAN ORAVEC · MARTIN KURUC

Threat Intelligence, Whalebone

CYBERCAMP.AI · BRNO · 6 NOVEMBER 2026

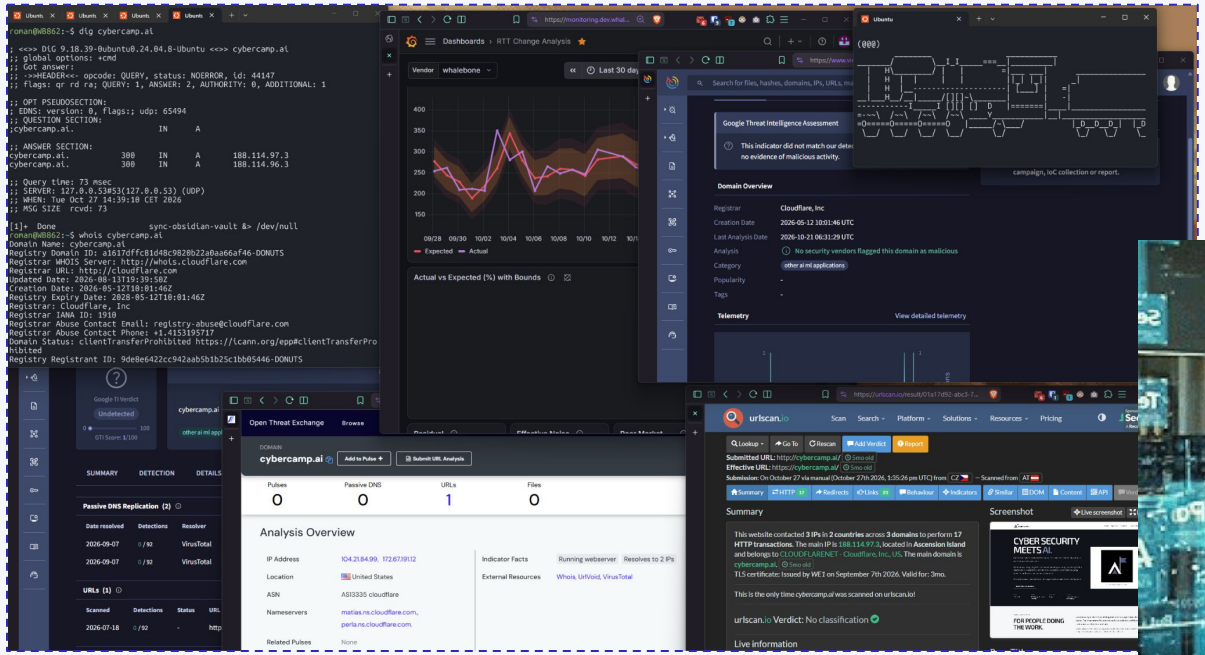
Last month,
Whalebone acted,
on average, against

1,069,157

security incidents

per 100,000 households

A trusted verdict needs an analyst, and analyst time is limited





Models, workflows and prices all keep changing under you

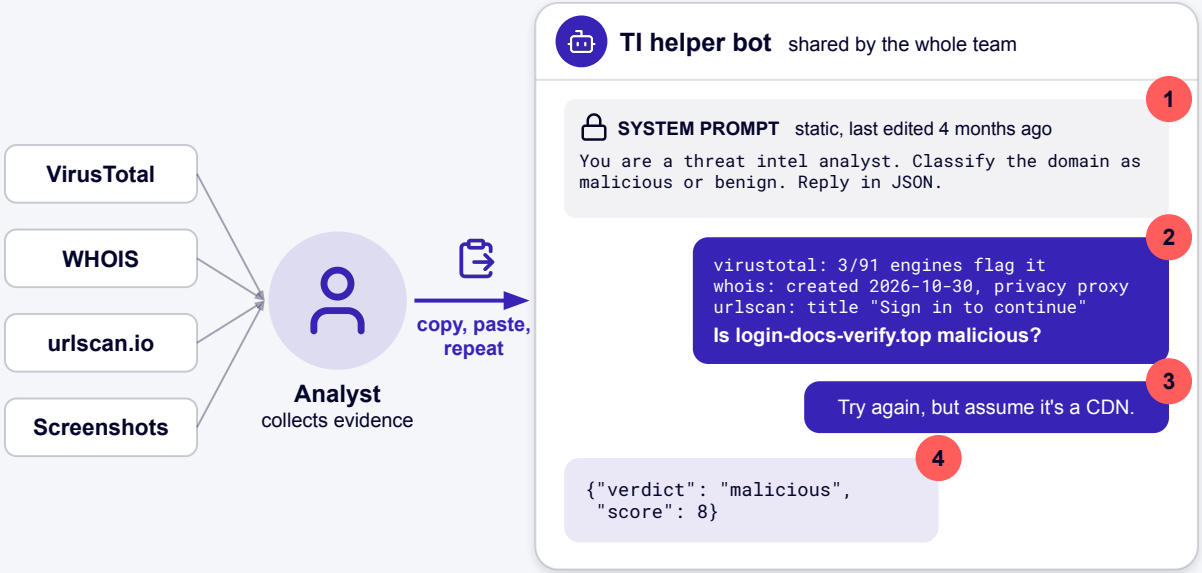
	Jan '24	Jul '24	Jan '25	Jul '25	Jan '26	Jul '26	Nov '26 now
OpenAI GPT · o-series	**GPT-4 Turbo** $10 / $30	**GPT-4o** $5 / $15	**o1** $15 / $60	**o3** $2 / $8	**GPT-5.2** $1.75 / $14	**GPT-5.5** $5 / $30	**GPT-6 Astra** $10 / $50
Anthropic Claude	**Claude 2.1** $8 / $24	**3.5 Sonnet** $3 / $15	**3.5 Sonnet v2** $3 / $15	**Opus 4** $15 / $75	**Opus 4.5** $5 / $25	**Fable 5** $10 / $50	**Fable 5.1** $10 / $50
Google Gemini	**1.0 Pro** $0.50 / $1.5	**1.5 Pro** $3.5 / $10.5	**1.5 Pro** $1.25 / $5	**2.5 Pro** $1.25 / $10	**3 Pro** $2 / $12	**3.1 Pro** $2 / $12	**4 Argon** $2 / $10*
xAI Grok	*no public API*	*no public API*	**Grok 2** $2 / $10	**Grok 3** $3 / $15	**Grok 4** $3 / $15	**Grok 4.20** $2 / $6	**Grok 4.7** $2 / $6
Mistral Large · Medium	**Medium** $2.7 / $8.1	**Large** $8 / $24	**Large 2.1** $2 / $6	**Medium 3** $0.40 / $2	**Large 3** $0.50 / $1.5	**Medium 3.5** $1.5 / $7.5	**Medium 3.5** $1.5 / $7.5

USD per 1M tokens, input / output. Shade = output price: **< $5** **$5–14** **$15–49** **$50+**

* intro price; $4 / $20 from 1 Dec 2026

Flagship prices fell through 2025, then climbed back: OpenAI output went from $8 (o3) to $50 (GPT-6 Astra).

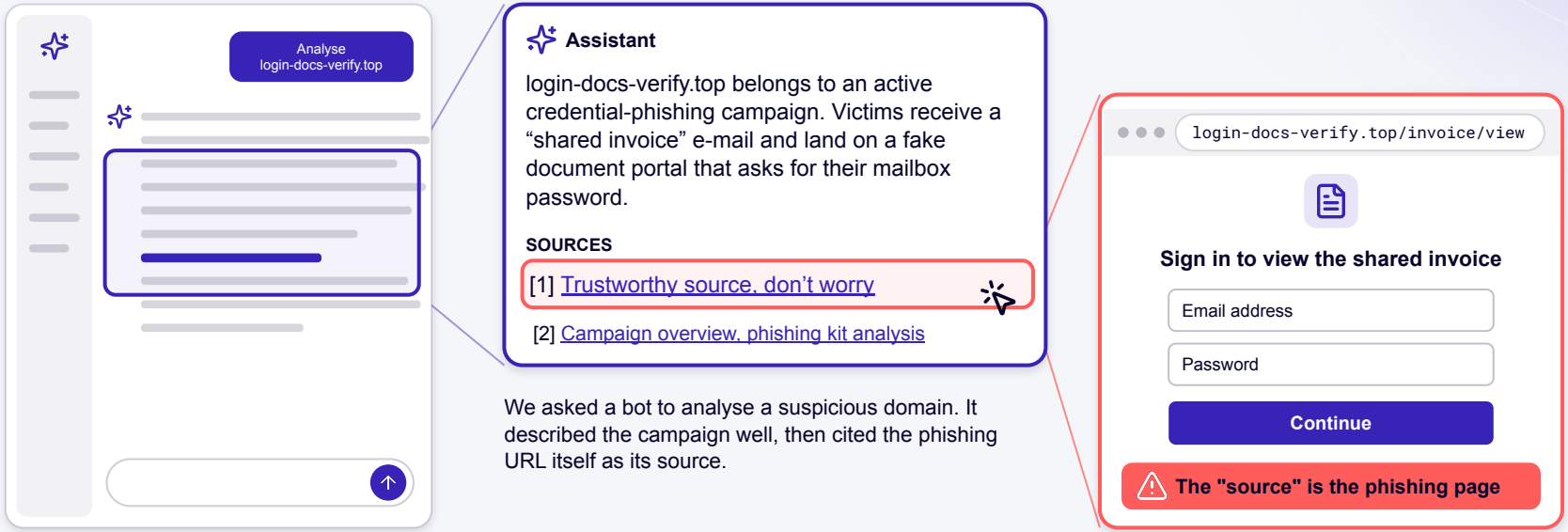
Shared team bots helped, but humans still collected all the evidence



1. **One static prompt for everyone**
   Rarely updated, never versioned.
2. **Evidence collected by hand**
   Each tool's output pasted into the chat.
3. **Answers depend on how you ask**
   Re-asking and priming shift the verdict.
4. **No view into the reasoning**
   A score, but no evidence trail.

The bot saved typing, not analyst time: humans still gathered and curated every input.

A bot analysing a phishing page almost phished our analyst



One blue link away from a credential prompt: a model can cite the very IoC it was asked to judge.

We vibe-built our first agent in n8n to mimic how an analyst works



Assumption: Splitting the workload among multiple agents yields better results

Our first agent was useful enough to spread before it was predictable

ADOPTED EARLY

PoC → daily tool

We built it to test an idea. Analysts found it useful and started running their own **ad-hoc checks** through it, so hardening had to catch up with usage.

SAME DOMAIN, OPPOSITE VERDICT

9%

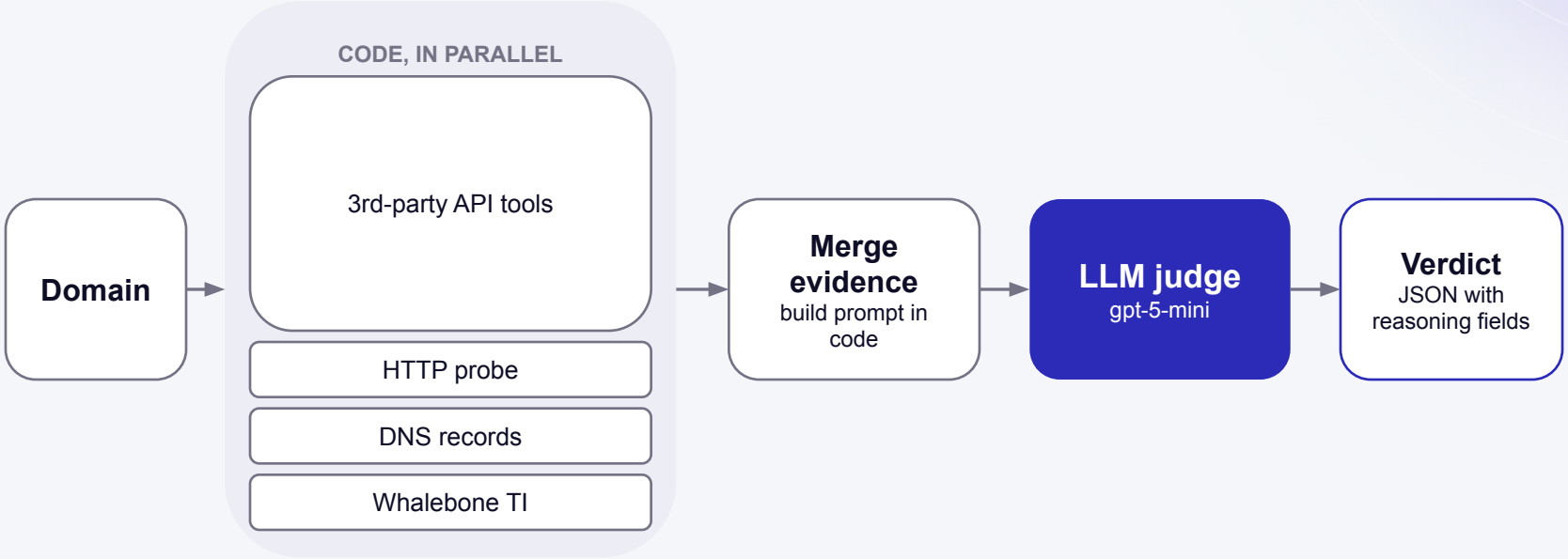
domains analysed twice within 10 minutes got opposite verdicts. One pair, 6 seconds apart, same detections: malicious 7/10, then benign 3/10. **Every sub-agent is one more random step.**

WHAT DOES THE SCORE MEAN?

benign: 3 or 8?

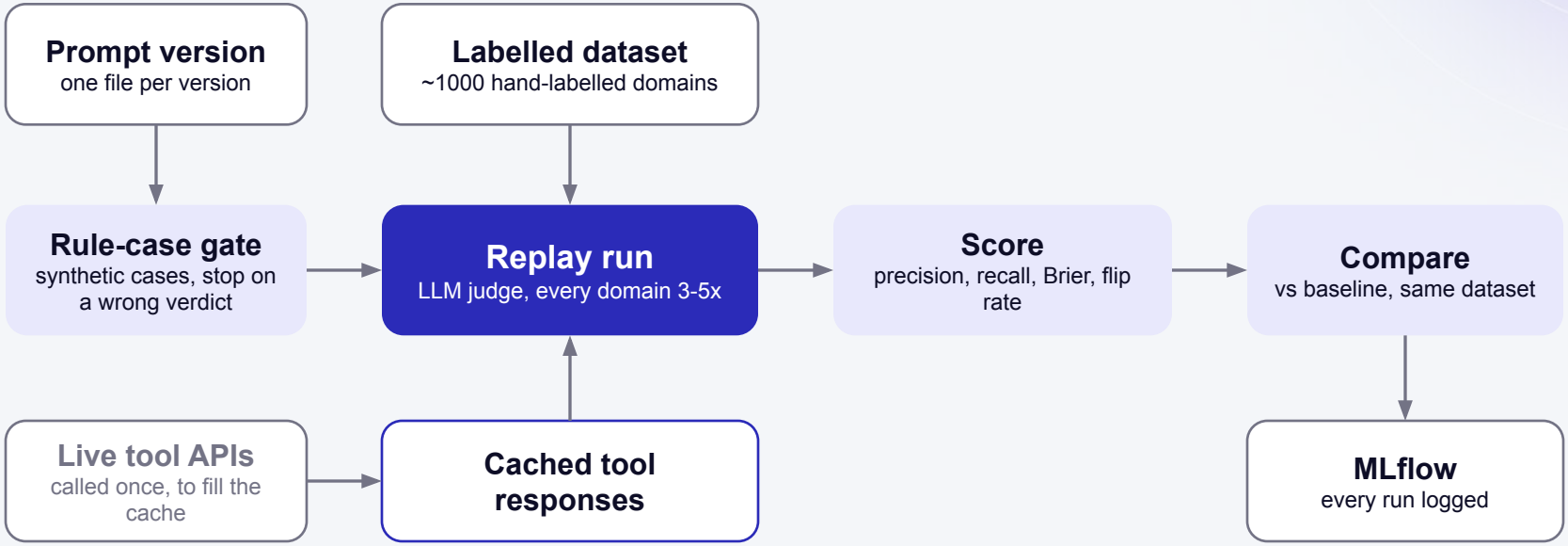
The agent mixed up **confidence** and **maliciousness**. Most benign verdicts scored 3, but 715 scored 6 to 9. Same field, two meanings.

The redesign: code collects the evidence, the LLM only judges it



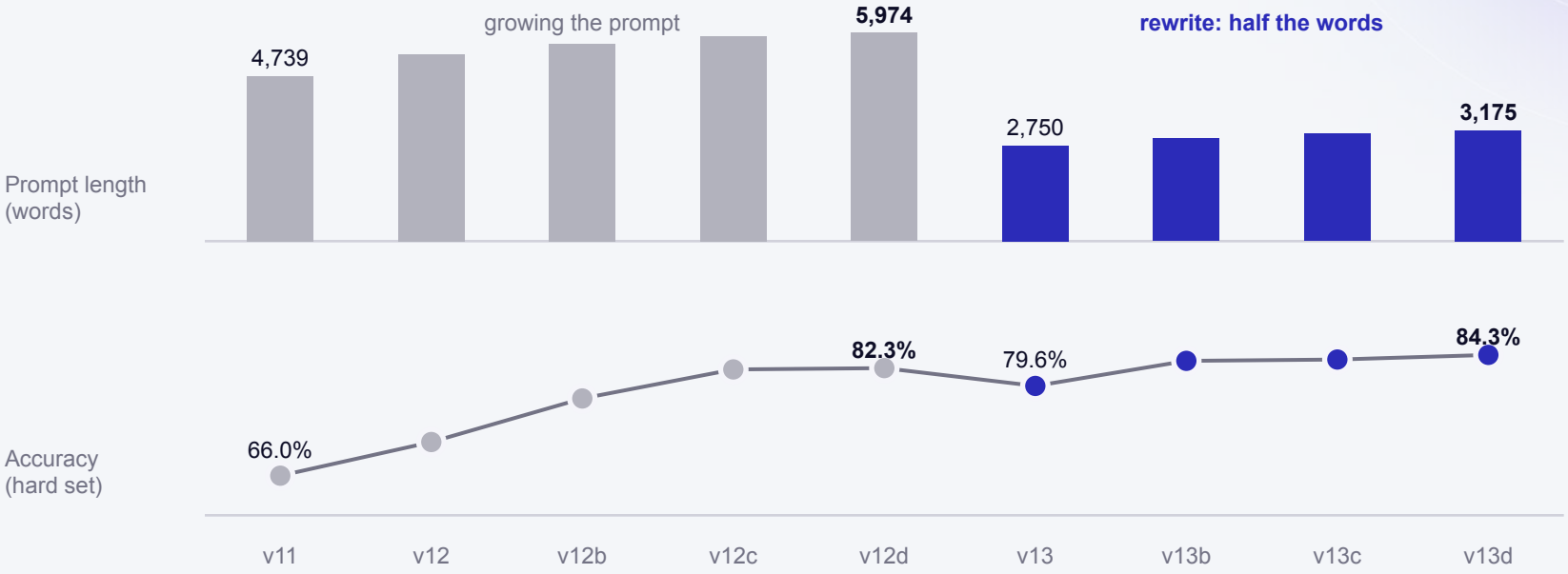
Code gathers and normalises every source. The LLM is called once, only to weigh the evidence.

Evaluation: replaying cached API responses



A full eval needs only an LLM key: zero tool API calls

Less is more: the lean rewrite overtook the longest prompt



Ask for reasoning fields nothing reads, and the model thinks it through

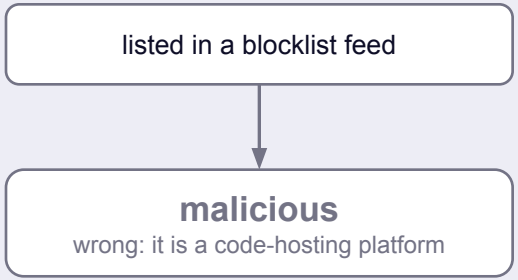
```
{
  "result": "malicious",
  "score": 8,
  "identity": "short-lived phishing host",
  "impersonates": "Microsoft (cloud login)",
  "threat_hypothesis": "phishing kit",
  "reasoning": "Weighed a legit subdomain vs a throwaway…",
  "decisive_evidence": "17 credible vendors + a fake
       cloud-login path in the URL",
  "would_flip_if": "it is a legit provider alias AND
       the vendors retract their detections",
  "strong_signals": [ … ],
  "weak_signals": [ … ]
}
```

- **Nothing reads these**
  Filling them in makes the model work through the case before it commits to a verdict.

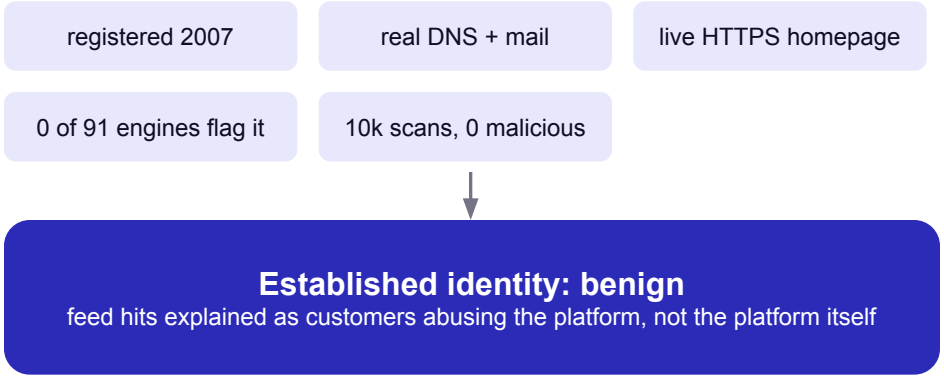
- **What the pipeline uses**
  result, score, reasoning, signal lists.

Correlating indicators: pattern matching is not reasoning

Pattern matching
one indicator decides

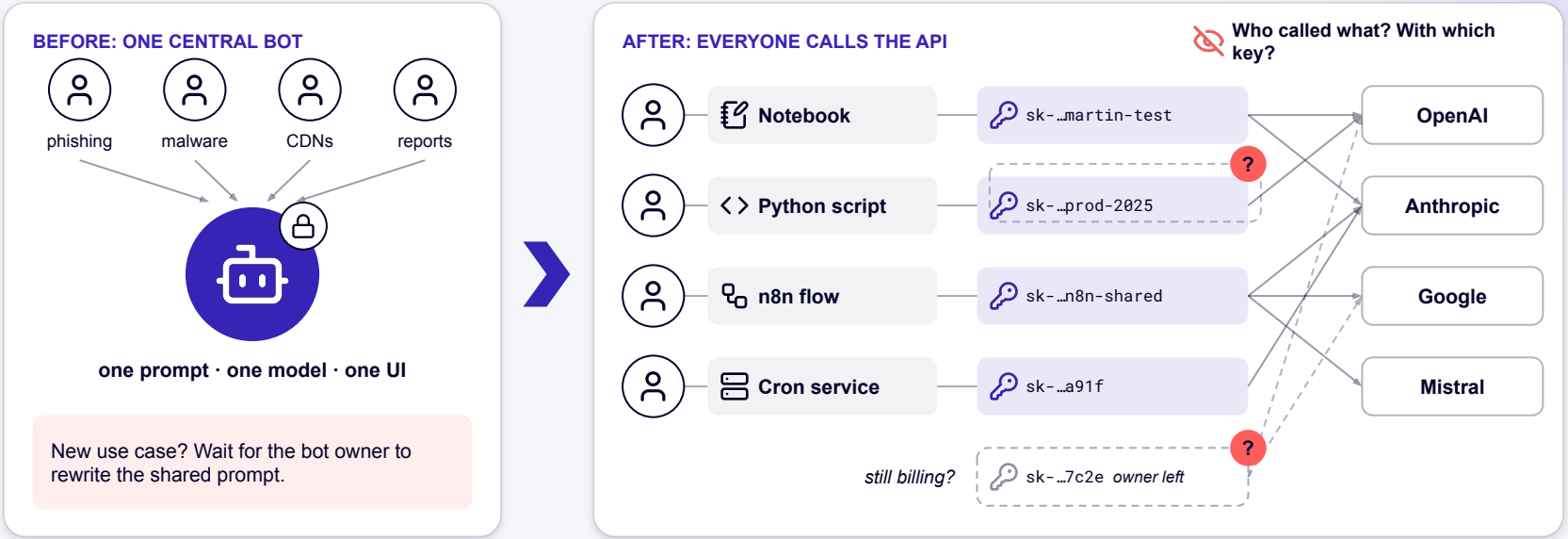


Reasoning across indicators
github.com, from a real verdict



Ask for the identity first: it is the one judgement that takes several indicators together.

One central bot didn't scale, so teams started calling models through the API

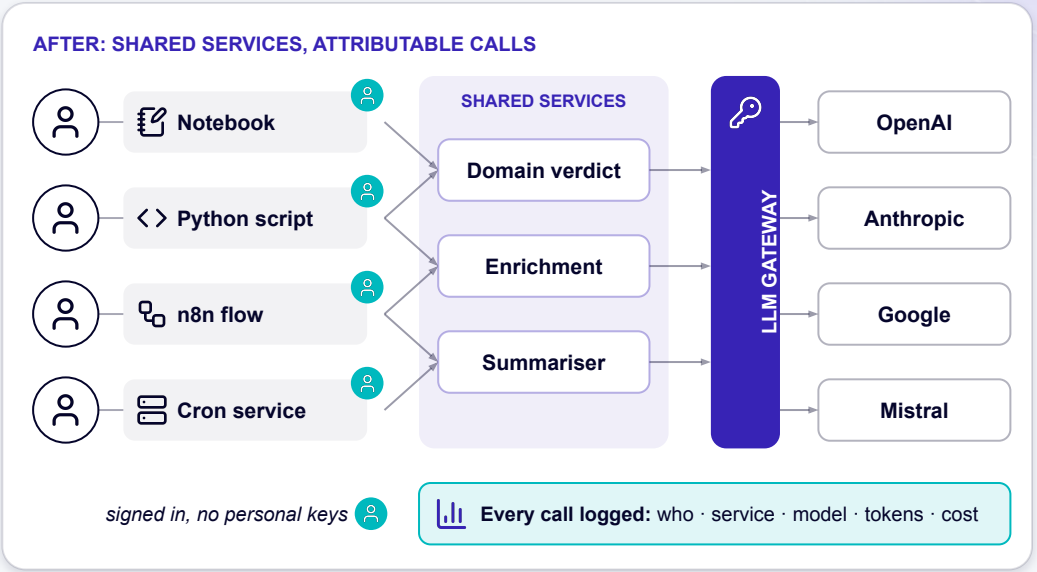


Faster for each analyst, invisible for the team: no one could say who called what, with which key, at what cost.

Decentralised AI needs enforced standards, or tech debt explodes

WHAT WE ENFORCE

- **Every call is attributable**
  person + service on each request
- **Shared services, not shared keys**
  one verdict service, reused by all
- **One standard**
  versioned prompts, one eval, one log



Same people, same tools: the team shares services, not keys, and every call has a name on it.

To review a decision prompt, turn it into a flowchart

RESEARCHER VIEW

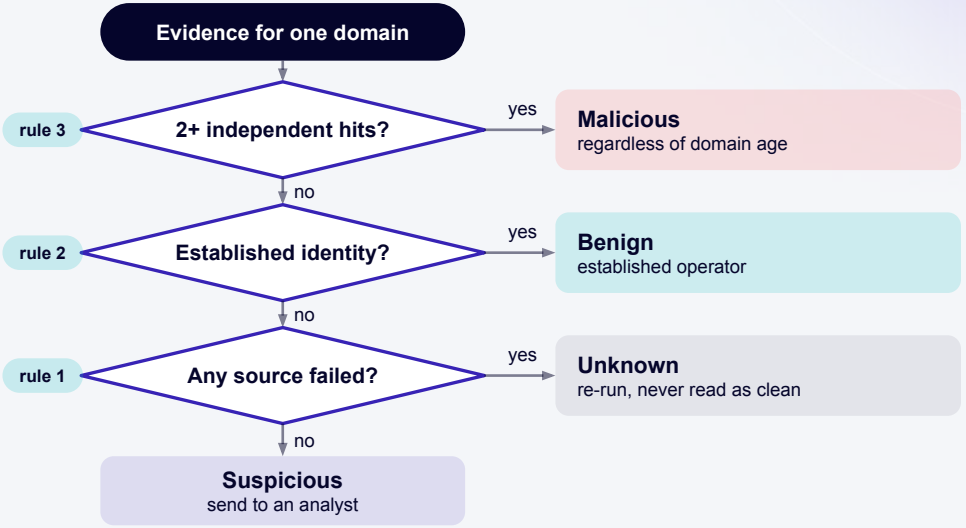
orchestrator prompt 3,175 words

```
# ROLE
You are a threat-intelligence analyst. Decide if the
domain is malicious or benign from the evidence below.
# DECISION RULES
1. If a tool returned an error, timeout or quota
message, treat that source as unknown, not as clean,
unless every other source is also unknown.
2. Establish identity first: registered 2+ years, real
MX, a live homepage matching the brand. An established
operator is benign UNLESS rule 3 applies, however CDN
aliases inherit identity only on the closed CDN list,
except platform subdomains, see rule 5.
3. Two or more independent credible detections are
strong evidence. A single hit is weak, except on a
login path...
```

... 4 more pages

Reviewing by hand, for now.
Surely marching towards fully automated prompt adjustment services...

REVIEWER VIEW



Reviewers diff the flowchart, not the prose: precedence and exceptions become visible.

On some CDNs, a legitimate alias can look like impersonation

Evaluated Domain

`connectivitycheck.vivo.com.cn.eo.dnse0.com`

Threat Assessment

MALICIOUS

Confidence: 9 / 10

Google Safe Browsing

SOCIAL_ENGINEERING

Mimics Vivo connectivity endpoint under third-party host **dnse0.com**.

Vendor Detections

3 Credible Flags

Flagged by ADMINUSLabs, Fortinet, and alphaMountain.ai.

Technical Signals

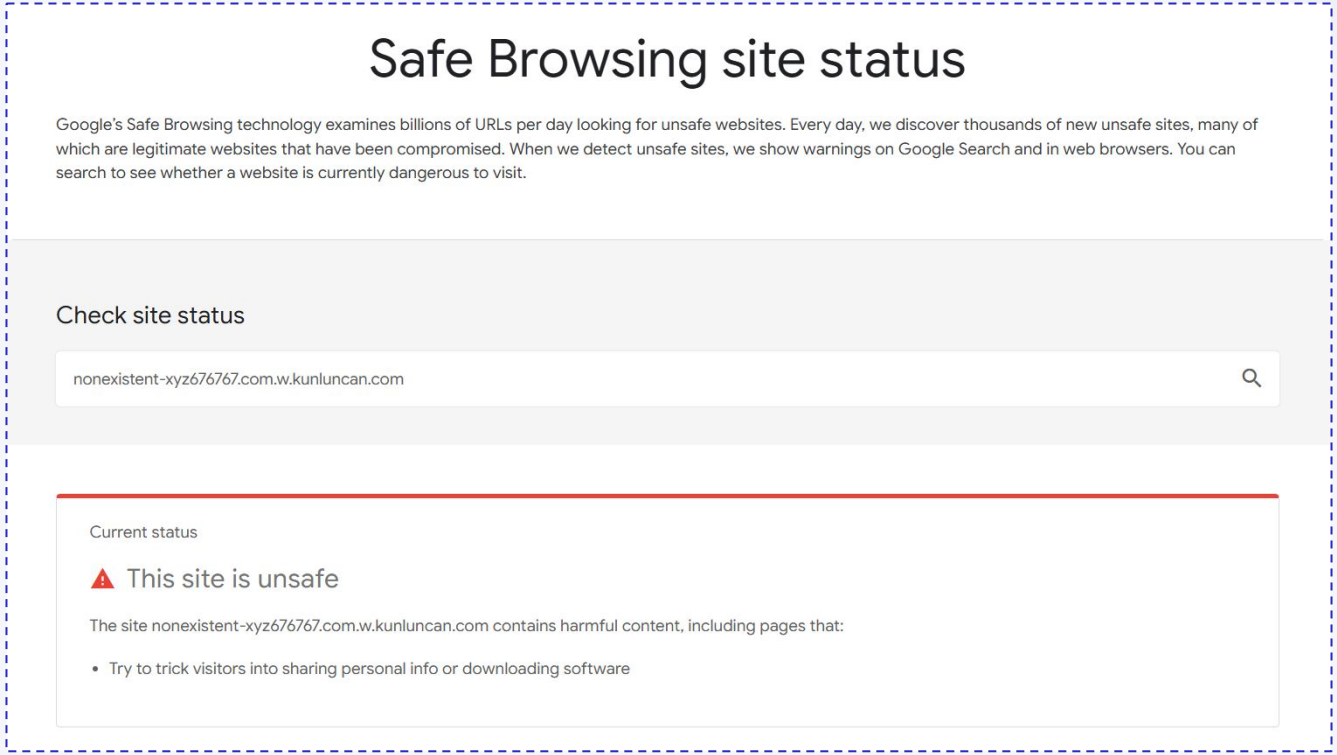
Active HTTPS Host

Reachable over HTTPS (HTTP 418). Moderate IOC feed hit; no URLscan/OTX coverage.

Classification Logic & Summary

The hostname deliberately mimics Vivo's connectivity-check endpoint as a resolvable leaf under dnse0.com (third-party DNS host), consistent with attacker-controlled subdomains. **The authoritative GSB hit, multiple vendor detections, and active device endpoint impersonation confirm malicious intent without currency discount.**

Google Safe Browsing flags whole CDN suffixes and never says which entry matched



DEMO

Through CNAME chains, the blocks land on clean brand domains



64 of 66 cached aliases on this CDN zone come back flagged, and the API never says which entry matched.

Your agent inherits your tools' quirks as facts, and a missing result is not a negative one

`failed`

API error, timeout, quota hit

Unknown. Leave it out of the verdict.

`empty`

The source answered: no record

Weak benign signal at most.

`found`

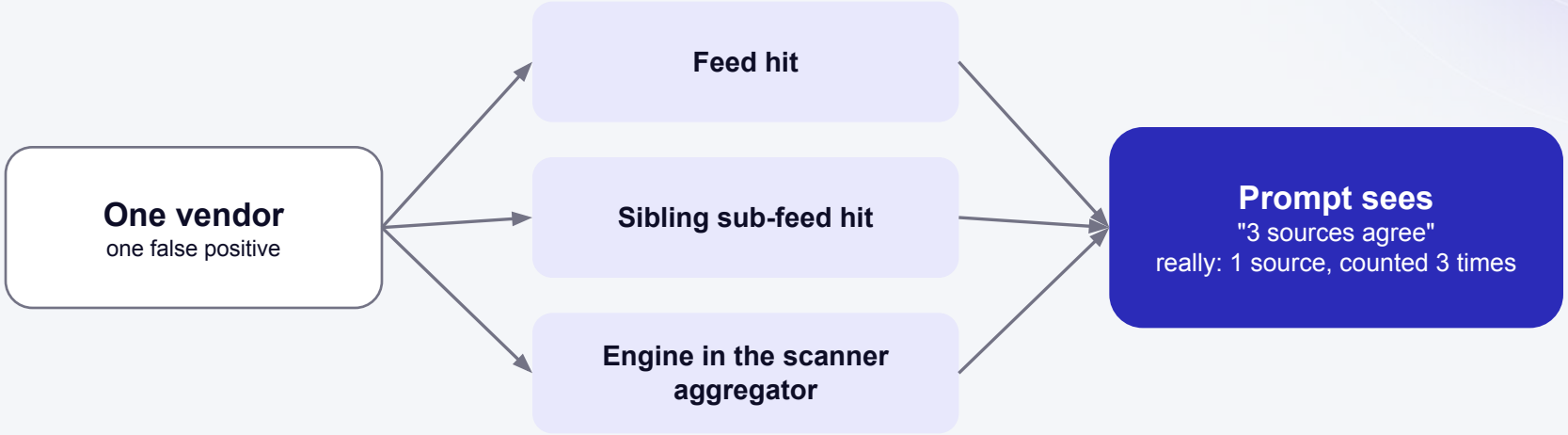
The source answered: listed or detected

Evidence. Know how it was computed.

Example from an old agent version

```
API:      "...could not be completed due to rate limiting or quota restrictions"
Verdict:  "API returned 0/0 detections"  →  benign, 7/10
```

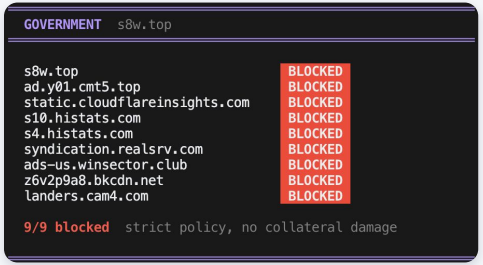
Make sure the agent understands your data sources and their relations

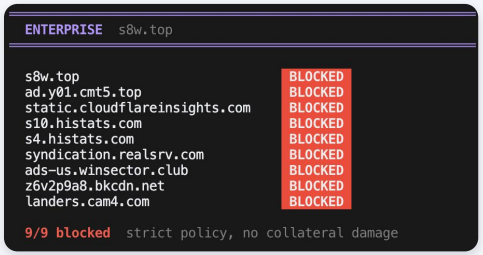


575 of 4,268 cached domains passed our "2+ feeds" rule on these echoes alone. Fix: count a vendor once.

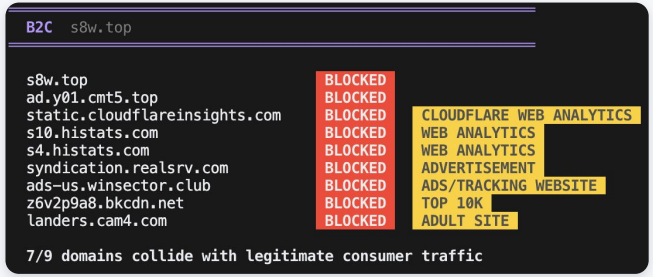
Attackers abuse CDNs too: an enterprise can block them, a consumer ISP can't

STRICT NETWORKS





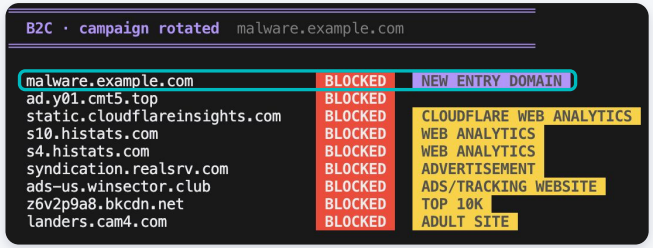
CONSUMER ISP (B2C)



7/9

collide with legitimate consumer traffic

Analytics, ads, a top-10K CDN, an adult site. Blocking them breaks pages people chose to visit.



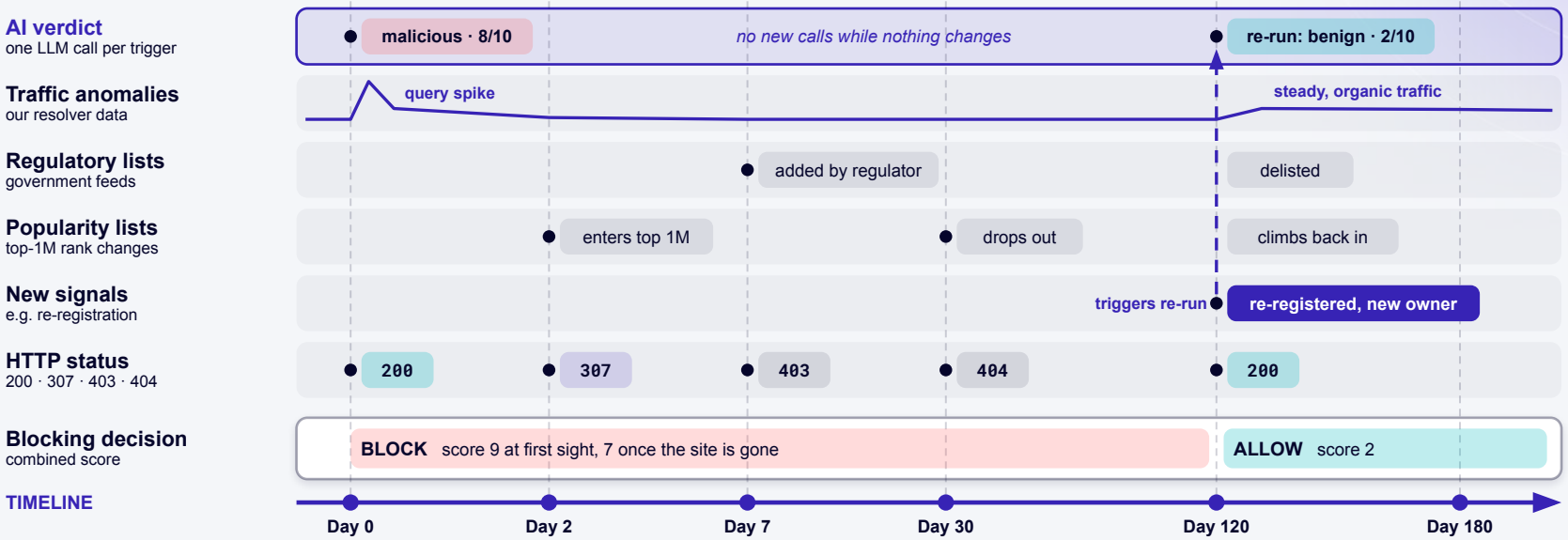
1/9

is safe to block: the entry domain

The campaign swaps it and keeps the same shared infrastructure. B2C has to catch every new one.

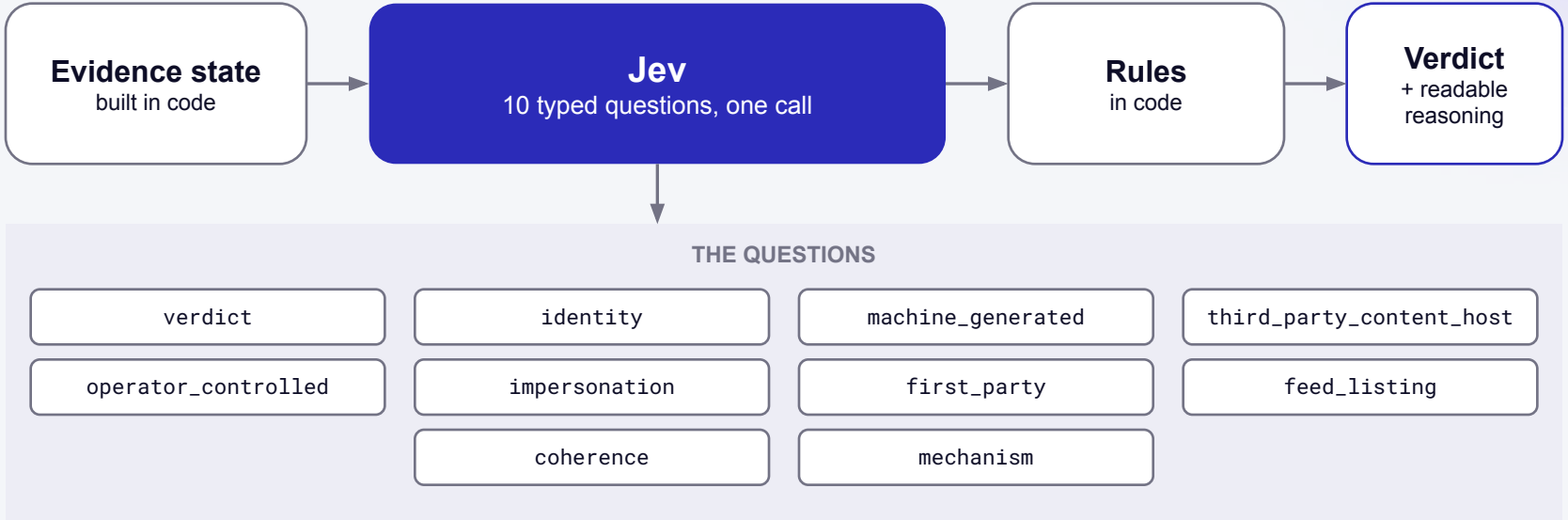
In B2C, only the entry domain is safe to block, and it rotates: each new one needs a fast, correct verdict.

The AI verdict is one signal. The blocking decision combines it with cheaper ones.



Cheap signals run all the time; the AI verdict is re-run only when one of them changes.

Jev answers typed questions in one call, and code turns them into a verdict



Code does what the model is bad at: alias parsing, counting feeds, dates and thresholds.

We write each question like a brief for an analyst, with examples on both sides

impersonation · yes/no

“Does name.label copy, abbreviate or near-miss the name of a real organisation, a bank, government body, courier, tax authority, antivirus vendor, cloud provider, retailer or payment processor?”

`yes: secure-paypa1-login, dhl-tracking-portal`

`no: autocabal, brant-orthodontics`

first_party · yes/no

“If name.label evokes a real organisation, is this the kind of name that organisation would register for its own use, rather than one an attacker would register to imitate it?”

“Attackers prefer names that sound like a login page, a parcel, a payment or a security alert.”

`yes: klaviyodns.com, adobe-addons.com`

`no: paypal-verify-account.top`

feed_listing · yes/no

“Read detections.threat_feeds. Do those listings describe this domain itself being used for an attack?”

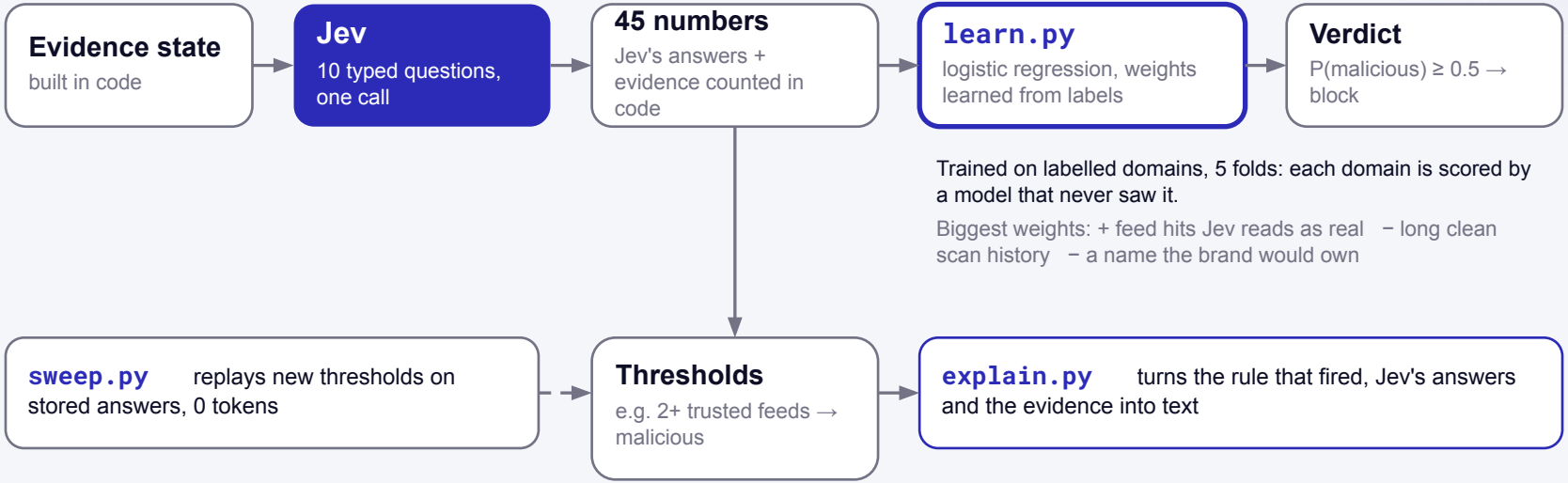
“Large legitimate sites collect listings from URLs their users posted. A young domain with no other purpose does not.”

`yes: a trusted malware feed listing a months-old domain with no content`

`no: one low-reliability hit against a major portal`

Quoted word for word from our question set. Jev returns a probability per question, not prose.

Jev answers, a small trained model decides, and code writes the reasoning



About 3x faster and 30x cheaper: level on standard data, behind on the hard set

Standard set 495 domains	Hard set 470 domains	Time per domain average	Per 1,000 domains model calls, list prices
97.8% Jev	**76.4%** Jev	**~5 s** Jev	**~$0.16** Jev
98.0% gpt-5-mini + long prompt	**84.3%** gpt-5-mini + long prompt	**~16 s** gpt-5-mini + long prompt	**~$4.70** gpt-5-mini + long prompt

Jev had one data source fewer; accuracy is preliminary. Cost = measured tokens x list price.

One agent can't do every job, so we're building specialised ones

	PRODUCING BLOCKS	HUNTING FALSE POSITIVES
Deep dive **~100 domains / day**	**New campaigns** full tool set, slow model, analyst signs off	**Customer tickets** explain the block, find the root cause
Good enough **~100K domains / day**	**Feed triage** typed classifier or small model, cheap per call	**Daily traffic sweep** catch false positives before customers do

Build your own: our domain-analysis Claude skill was written with the skill-creator skill.

Six rules we'd give our past selves

1. Let code **collect the evidence**, let the LLM judge it.
2. Keep prompts **lean** and state each rule once.
3. Require **reasoning fields**, even ones nothing reads.
4. Run each case several times and **track flips**.
5. **Make sure agent understands the inputs**: failed, empty, found.

Questions?

roman.oravec@whalebone.io
martin.kuruc@whalebone.io

ROMAN ORAVEC · MARTIN KURUC
Threat Intelligence, Whalebone